

University of Batna 2

Chapter 0

Review

University of Batna 2

جامعة باتنة
UNIVERSITY OF BATNA 2

Review: Information and Data Security

UNIVERSITY OF BATNA 2

Rappel

Cybersécurité: **C'est quoi ?**

Rappel

Cybersécurité

Ensemble de **solutions et techniques** mises en place afin de

- non seulement, **protéger les biens d'une entreprise** (données sensibles, systèmes informatiques, réseaux, et applications logicielles) contre les cyber-attaques,
- mais aussi de **pouvoir faire face** si l'un des biens est attaqué (analyse forensic, reverse engineering) et de **remettre le bon fonctionnement** des biens après l'attaque (**Recovery**).

La cybersécurité consiste aussi à **protéger l'image de l'entreprise**.

Rappel

Personnes utilisant les menaces pour casser notre sécurité et ainsi gagner l'accès aux biens de l'entreprise (Pirates)

Menace: méthodes essayant de casser notre sécurité
Virus, Vers, Phishing, etc

Sécurité:
Sécurisé les biens (chiffrement, AV, FW, Proxy, etc)

Biens:
Serveurs, machines,
données sensibles,
réseaux, applications, etc.

Rappel

Qu'est-ce qu'un attaquant ?

Actions malveillantes

- Voler des informations
- Supprimer des données
- Chiffrer des fichiers
- Nuire à un système
- etc.

Actions bienveillantes

- Contribuer à l'amélioration de la sécurité d'un système

Rappel



Analyse de vulnérabilités

Les vulnérabilités sont **le maillon faible** de tout système dans une organisation.

Une fois la vulnérabilité découverte, elle peut être exploitée par des personnes malveillantes pour gagner l'accès à un système et le nuire.

Plusieurs éléments peuvent être la cause d'une vulnérabilité, nous citons

- Mauvaise configuration d'un système
- Mots de passe faibles
- Failles d'application
- Failles de système d'exploitation
- Non mise à jour des solutions utilisées
- etc.

Analyse de vulnérabilités

Notation des vulnérabilités

CVE (Common Vulnerabilities and Exposures)

CVSS (Common Vulnerability Scoring System)

NVD (National Vulnerability Database)

CVE-2021-44228

CVSS v3.0 Ratings

Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0

Information Technology Laboratory
NATIONAL VULNERABILITY DATABASE

NVD

VULNERABILITIES

🔍 CVE-2021-44228 Detail

UNDERGOING REANALYSIS

This vulnerability has been modified and is currently undergoing reanalysis. Please check back soon to view the updated vulnerability summary.

QUICK INFO

CVE Dictionary Entry:
CVE-2021-44228
NVD Published Date:
12/10/2021

Analyse de vulnérabilités

<https://www.cvedetails.com/cve/CVE-2021-44228/>

CVE Details

The ultimate security vulnerability datasource

[Log In](#) [Register](#)

(e.g.: CVE-2009-1234 or 2010-1234 or 20101234)

Search

View CVE

Vulnerability Feeds & Widgets^{New}

www.itsecdb.com

[Switch to https://](#)

[Home](#)

Browse :

[Vendors](#)

[Products](#)

[Vulnerabilities By Date](#)

[Vulnerabilities By Type](#)

Reports :

[CVSS Score Report](#)

[CVSS Score Distribution](#)

Search :

[Vendor Search](#)

[Product Search](#)

[Version Search](#)

[Vulnerability Search](#)

[By Microsoft References](#)

Top 50 :

[Vendors](#)

[Vendor Cvss Scores](#)

[Products](#)

[Product Cvss Scores](#)

[Versions](#)

Other :

[Microsoft Bulletins](#)

[Bugtraq Entries](#)

[CWE Definitions](#)

Vulnerability Details : [CVE-2021-44228](#)

Apache Log4j2 2.0-beta9 through 2.15.0 (excluding security releases 2.12.2, 2.12.3, and 2.3.1) JNDI features used in configuration, log messages, and parameters do not protect against attacker controlled LDAP and other JNDI related endpoints. An attacker who can control log messages or log message parameters can execute arbitrary code loaded from LDAP servers when message lookup substitution is enabled. From log4j 2.15.0, this behavior has been disabled by default. From version 2.16.0 (along with 2.12.2, 2.12.3, and 2.3.1), this functionality has been completely removed. Note that this vulnerability is specific to log4j-core and does not affect log4net, log4cxx, or other Apache Logging Services projects.

Publish Date : 2021-12-10 Last Update Date : 2022-03-15

[Collapse All](#) [Expand All](#) [Select](#) [Select&Copy](#)

[▼ Scroll To](#)

[▼ Comments](#)

[▼ External Links](#)

[Search Twitter](#) [Search YouTube](#) [Search Google](#)

– CVSS Scores & Vulnerability Types

CVSS Score	9.3
Confidentiality Impact	Complete (There is total information disclosure, resulting in all system files being revealed.)
Integrity Impact	Complete (There is a total compromise of system integrity. There is a complete loss of system protection, resulting in the entire system being compromised.)
Availability Impact	Complete (There is a total shutdown of the affected resource. The attacker can render the resource completely unavailable.)
Access Complexity	Medium (The access conditions are somewhat specialized. Some preconditions must be satisfied to exploit)
Authentication	Not required (Authentication is not required to exploit the vulnerability.)
Gained Access	None
Vulnerability Type(s)	Execute Code
CWE ID	502

Rappel

جامعة باتنة
UNIVERSITY OF BATNA 2

Méthodes d'attaques

UNIVERSITY OF BATNA 2

Méthodes d'attaques

1. **Attaques par code malicieux**
2. **Attaques sur les protocoles réseau**
3. **Attaques sur les programmes**
4. **Attaques par messagerie électronique (Ingénierie sociale)**

Other classifications exist

Méthodes d'attaques

1. Attaques par code malicieux

Un code malicieux (malware en anglais; **Malicious Soft**ware) désigne un **logiciel malveillant** très utilisé dans la cybersécurité et **développé dans le but de nuire à un système informatique.**

Il existe plusieurs type de malware

- Virus informatiques
- Vers informatiques
- Malwares espions (spyware)
- Chevaux de troie
- Adwares
- Rançongiciels (ransomware)
- Cryptominers
- Chiffreurs (crypters)
- Scarewares
- Portes dérobées
- Générateurs de clés

Méthodes d'attaques

2. Attaques sur les protocoles réseau

Ce type d'attaque est lié principalement **aux failles des protocoles réseaux.**

Nous citons quelques attaques bien connues

- IP Spoofing
- ARP Spoofing
- DNS Spoofing
- Attaques par Fragmentation
- TCP Session Hijacking
- Man In The Middle (MITM)
- Déni de service (DoS)
 - TCP SYN Flooding
 - UDP Flooding
 - Smurf
 - DDoS

Méthodes d'attaques

3. Attaques sur les programmes

Ce type d'attaques **se base sur des failles au niveau des programmes** utilisés.

Nous citons

- Buffer overflow
- Attaques par injection
- Défacement de site web

Méthodes d'attaques

4. Attaques par messagerie électronique (Ingénierie sociale - social engineering)

Ce type d'attaques **se base sur la manipulation et l'influence des internautes** afin d'obtenir quelque chose en retour (argent, information confidentielle, etc.).

=> Dans ce cas, la faille humaine est la clé pour la réussite de ces attaques.

Ces attaques sont **difficile à détecter par les technologies de protection.**

Nous citons quelques exemples d'attaques via la messagerie électronique

- Phishing
- Scam
- SPAM

Méthodes d'attaques

Les attaques par messagerie électronique (Ingénierie sociale):

Ce type d'attaques **se base sur la manipulation et l'influence des internautes** afin d'obtenir quelque chose en retour (argent, information confidentielle, etc.). **Dans ce cas la faille humaine est la clé pour la réussite de ces attaques.**

Ces attaques sont **difficile à détecter par les technologies de protection**. Nous citons quelques exemples d'attaques via la messagerie électronique:

- Phishing
- Scam
- SPAM

Questions

Est-ce que le phishing est un malware?

Est-ce que l'attaque DDoS est un malware?

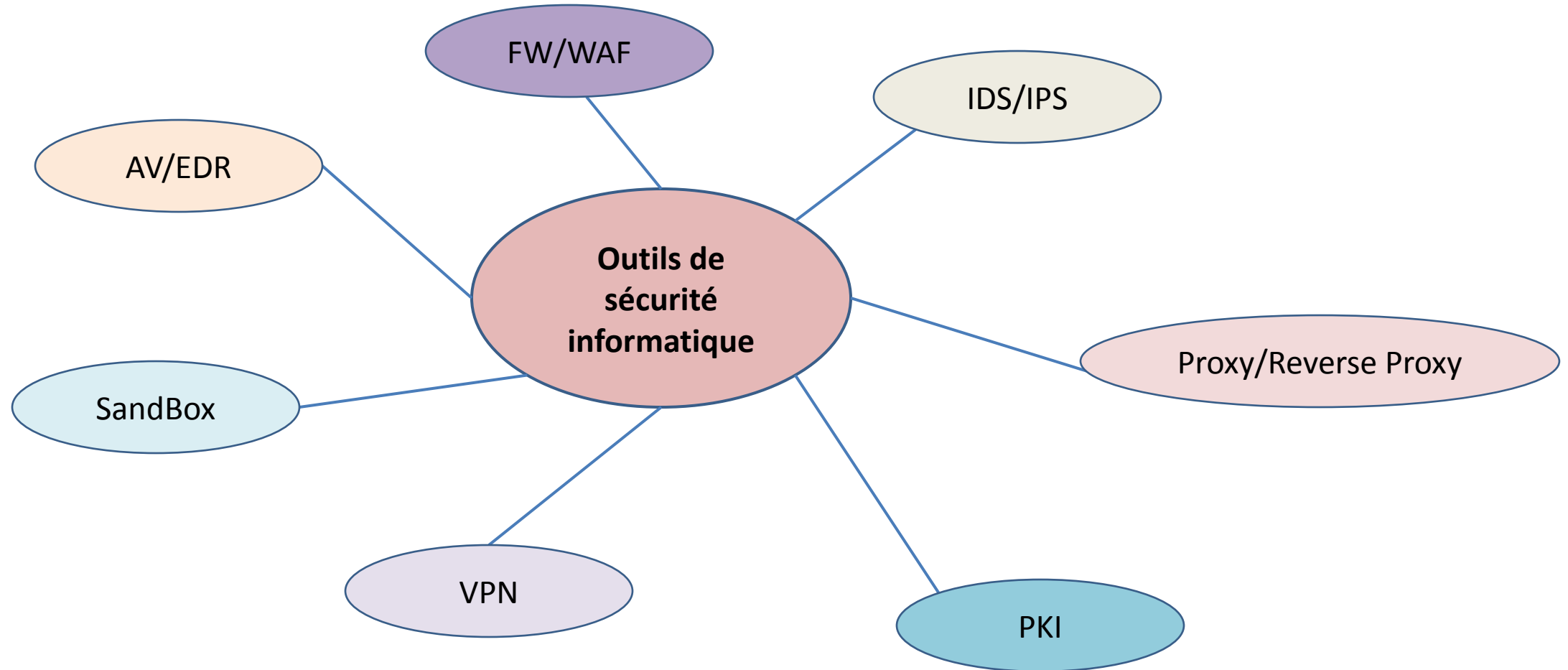
Rappel

جامعة باتنة
UNIVERSITY OF BATNA 2

Outils de détection/protection contre les attaques en entreprise

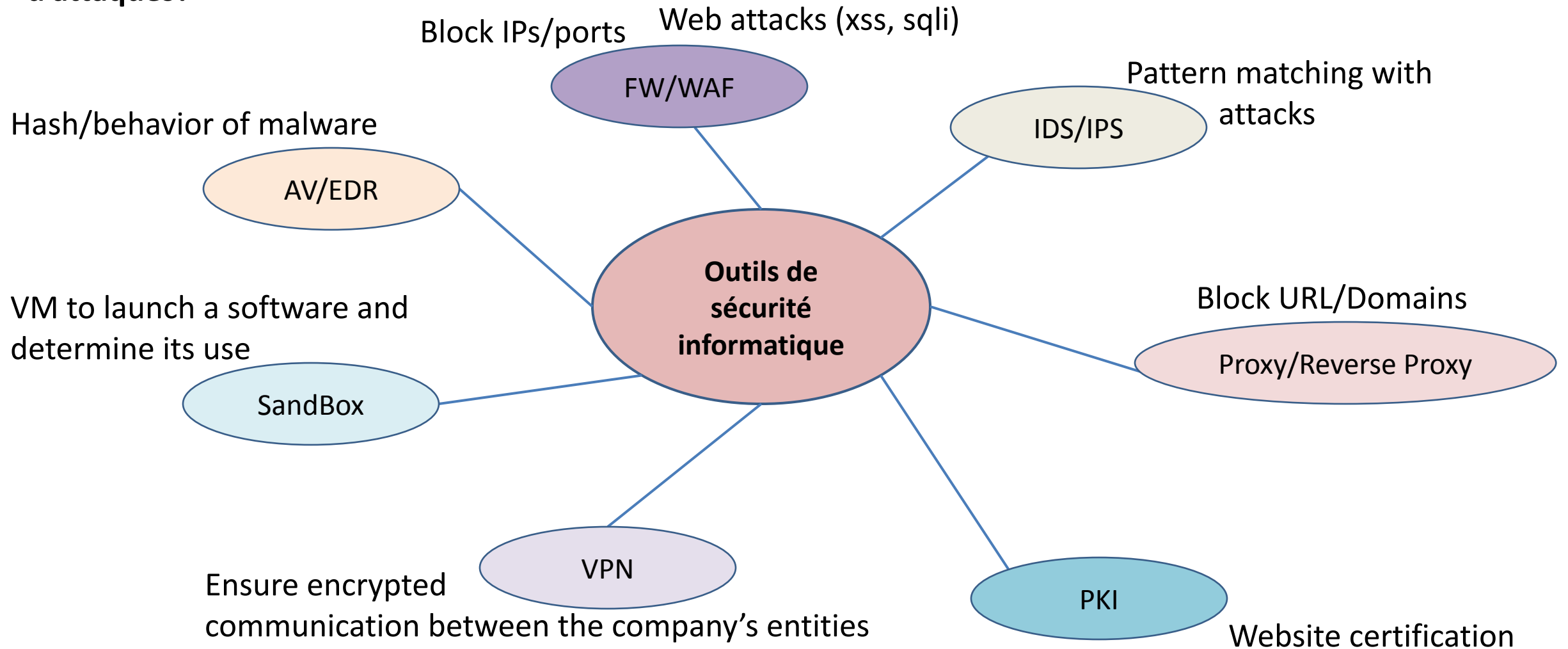
UNIVERSITY OF BATNA 2

Rappel

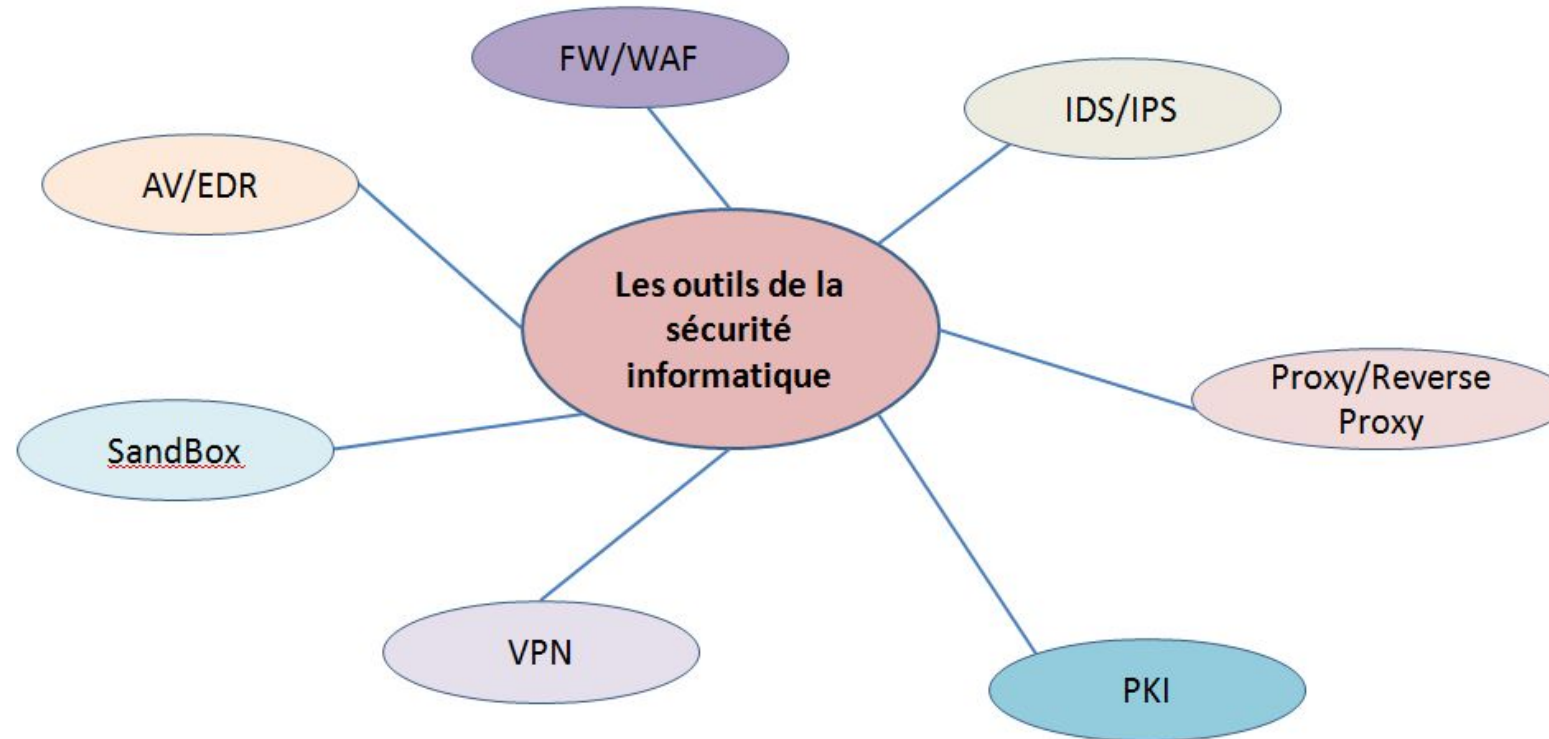


Est-ce que la DMZ est un
outils de détection
d'attaques?

Rappel



Rappel



Comment les équipes de sécurité sont-elles alertées de chaque technologie (ou outil de détection)?

Quelques éléments de prévention d'attaques (1/2)

Outils de sécurité: installation de plusieurs outils de sécurité (AV/EDR, FW, Proxy, IDS/IPS, WAF, etc.) sur plusieurs niveaux, les mettre à jour et faire des scans réguliers.

Veille: vérification constante des systèmes (e.g., half an hour everyday) et s'assurer qu'il n'y pas de modifications ou accès non autorisés sur ces derniers. (e.g., Qualys, Tenable, Nessus)

- La veille consiste aussi à être à jour sur les nouvelles vulnérabilités sur les différentes technologies utilisées au sein de l'entreprise et l'application de patches.

Sauvegarde: faire des sauvegardes permettra de récupérer le système en cas d'attaque(s).

Quelques éléments de prévention d'attaques (2/2)

Mots de passe: utilisation d'une politique de mot de passe stricte

- Mot de passe long et difficile à deviner avec un changement régulier
- Ne pas utiliser le même mot de passe sur différentes plateformes.

Sensibilisation: consiste à sensibiliser les utilisateurs au sein de l'entreprise aux risques en termes de sécurité, et lancer des campagnes de sensibilisation afin d'évaluer le niveau de conscience des employeurs.

Vigilance: il faut rester constamment vigilant et faire des tests d'intrusion.

Plan de cours

- CHAPTER 0** Rappel
- CHAPTER 1** Outils de gestion et de traitement d'incidents (Siem/XDR, SOAR, Ticketing)
- CHAPTER 2** Endpoint Detection and Response (EDR)
- CHAPTER 3** Outils de détection de sécurité (FW, Proxy)
- CHAPTER 4** Outils de détection de sécurité (WAF)
- CHAPTER 5** DarkWeb et cyberSécurité

Plan de cours

- CHAPTER 0** Rappel
- CHAPTER 1** Outils de gestion et de traitement d'incidents (Siem/XDR, SOAR, Ticketing)
- CHAPTER 2** Endpoint Detection and Response (EDR)
- CHAPTER 3** Outils de détection de sécurité (FW, Proxy)
- CHAPTER 4** Outils de détection de sécurité (WAF)
- CHAPTER 5** DarkWeb et cyberSécurité